

# Stoquify Agent Credential Rotation Evidence Capture Runbook

---

**Date:** 2026-07-25

**Scope:** Phase 2A controlled internal pilot

**Decision boundary:** Evidence intake only; activation is never authorized

## Purpose

This runbook defines how Stoquify imports production credential classification, rotation, revocation, workload restart, new-version verification, and old-version rejection evidence from an independent security authority.

The collector does not rotate or revoke credentials. It accepts value-free references and timestamps only, validates them against the frozen inactive release, and binds the resulting credential register into the operational release register.

## Permanent Boundaries

- No credential, token, password, private key, connection string, database URL, authorization header, or raw environment may appear in the response, capture, register, report, log, or command output.
- The endpoint bearer secret is read from the process environment and is never retained.
- The collector cannot change the package state, operational declared status, governance, approvals, owners, scheduler, alerting, or activation.
- `activation.requested` and `activation.authorized` must remain `false`; `activation.activatedAt` and `release.activatedAt` must remain `null`.
- A passing capture updates evidence only. It does not approve internal activation or authorize Phase 3.

## Configuration

Required managed configuration:

```
STOQUIFY_AGENT_RELEASE_ENVIRONMENT
STOQUIFY_AGENT_CREDENTIAL_EVIDENCE_URL
STOQUIFY_AGENT_CREDENTIAL_EVIDENCE_SECRET
STOQUIFY_AGENT_CREDENTIAL_EVIDENCE_TIMEOUT_MS=20000
```

Requirements:

- The URL must be query-free HTTPS outside local development.
- URL user information, fragments, and query strings are rejected.
- The bearer secret must contain at least 32 characters.
- The timeout is bounded from 5 to 60 seconds.
- The response body is capped at 250 KB.

## Authority Endpoint Contract

The collector performs two `GET` requests:

1. A request with a random invalid bearer credential. It must return `401`.
2. A request with the managed bearer credential. It must return `200`.

The authenticated response must use this value-free shape:

```
{
  "ok": true,
  "data": {
    "ready": true,
    "environment": "internal_pilot",
    "registerId": "stoquify-agent-runtime-credential-response-2026-07-25",
    "incidentReference": "unsafe-local-browser-report-environment-scope",
    "sourceSystemReference": "security-system://stoquify/credential-rotation",
    "attestationReference": "attestation://security/credential-rotation/2026-07-25",
    "attestationDigest": "sha256:<64 lowercase hex characters>",
    "attestedAt": "2026-07-25T12:30:00.000Z",
    "securityOwnerDirectoryId": "directory://person/<real-security-owner>",
    "securityApprovalReference": "approval://security/<immutable-decision>",
    "release": {
      "packageId": "<frozen package id>",
      "releaseVersion": "<frozen release version>",
      "packageState": "PILOT_CERTIFIED",
      "commitSha": "<40 or 64 lowercase hex characters>",
      "artifactDigest": "sha256:<64 lowercase hex characters>",
      "deploymentReference": "deployment://<provider>/<immutable deployment>",
      "activatedAt": null
    },
  },
  "entries": [
    {
      "id": "agent-reconciler-credential",
      "disposition": "ROTATED_AND_REVOKED",
      "rotationEvidence": {
        "secretManagerReference": "secret-manager://<credential>/<new version>",
        "rotationOwnerDirectoryId": "directory://person/<real-security-owner>",
        "rotationStartedAt": "2026-07-25T11:00:00.000Z",
        "newVersionActivatedAt": "2026-07-25T11:05:00.000Z",
        "dependentWorkloadsRestartedAt": "2026-07-25T11:10:00.000Z",
        "newVersionVerifiedAt": "2026-07-25T11:15:00.000Z",
        "oldVersionRevokedAt": "2026-07-25T11:20:00.000Z",
        "oldVersionRejectedAt": "2026-07-25T11:25:00.000Z",
        "evidenceReference": "evidence://security/rotation/<credential>",
        "securityApprovalReference": "approval://security/<immutable-decision>",
        "reviewedAt": "2026-07-25T12:00:00.000Z"
      }
    }
  ]
}
```

## Credential-Class Completeness

Every entry already declared in the local credential register must appear exactly once. Missing, unexpected, duplicate, blank, or unresolved IDs fail the capture.

The current register contains 15 classes:

1. `primary-database-credential`
2. `payroll-immutability-database-credential`
3. `application-auth-signing-secret`
4. `legacy-nextauth-signing-secret`
5. `google-oauth-client-secret`
6. `email-server-credential`
7. `redis-connection-credential`
8. `public-identity-hmac-secret`
9. `public-receipt-signing-secret`
10. `history-cursor-signing-secret`
11. `payroll-destination-hmac-secret`
12. `upload-provider-secret`
13. `error-monitoring-dsn`
14. `agent-reconciler-credential`
15. `workflow-assurance-webhook-secret`

Allowed completed dispositions:

- `ROTATED_AND_REVOKED`
- `TEST_ONLY_CONFIRMED`
- `NOT_PRESENT_CONFIRMED`

`TEST_ONLY_CONFIRMED` and `NOT_PRESENT_CONFIRMED` still require a real security owner, immutable evidence reference, approval reference, and review timestamp.

## Validation

The capture fails closed unless:

- invalid authentication returns `401`;
- authenticated evidence returns `200`;
- environment, register ID, and incident reference match;
- the attestation is not future-dated and is no older than 24 hours;
- the security owner is a real directory or identity reference, not an E2E, test, seed, fixture, or demo identity;
- all entry approvals and rotation owners match the register-level security authority;
- timestamps are valid and ordered from rotation start through review;
- review precedes the authority attestation;
- the package is inactive and `PILOT_CERTIFIED`;
- package, release, commit, artifact, deployment, environment, and activation state match the operational release register;

- the existing register has no conflicting completed evidence.

## Commands

Generate a report without changing either register:

```
npm run agent:credential-rotation:evidence:report
```

Fail closed unless the capture is complete:

```
npm run agent:credential-rotation:evidence:gate
```

Apply a ready capture to both evidence registers:

```
npm run agent:credential-rotation:evidence:apply
```

The apply command:

1. Builds and reevaluates the complete credential register.
2. Preserves credential class purpose, environment-variable names, and dependent workloads.
3. Writes only dispositions, value-free evidence, authority metadata, release binding, owner, approval, and `declaredStatus: READY`.
4. Computes SHA-256 from the exact serialized credential-register bytes.
5. Updates only `credentialRotation` in the operational register with the register hash, capture hash, approval reference, and attestation reference.
6. Leaves operational status and activation unchanged.

If the process stops after the credential register is written but before the operational binding is written, the operational gate remains blocked by hash/reference mismatch. The failure mode is therefore fail-closed.

## Required Apply Order

The frozen release must exist before credential evidence can bind to it:

```
npm run agent:ci-release:evidence:apply
npm run agent:governance:evidence:apply
npm run agent:reconciler:evidence:apply
npm run agent:alert:evidence:apply
npm run agent:credential-rotation:evidence:apply
npm run agent:credential-rotation:gate
npm run agent:operational-release:gate
```

## Failure Codes

Important stable failures include:

- `CREDENTIAL_EVIDENCE_URL_MISSING`
- `CREDENTIAL_EVIDENCE_HTTPS_REQUIRED`

- CREDENTIAL\_EVIDENCE\_SECRET\_INVALID
- CREDENTIAL\_EVIDENCE\_INVALID\_AUTH\_NOT\_REJECTED
- CREDENTIAL\_EVIDENCE\_ENTRY\_ID\_DUPLICATE
- CREDENTIAL\_EVIDENCE\_ENTRY\_MISSING:<id>
- CREDENTIAL\_EVIDENCE\_ENTRY\_UNEXPECTED:<id>
- CREDENTIAL\_EVIDENCE\_FORBIDDEN\_VALUE\_FIELD
- CREDENTIAL\_EVIDENCE\_CAPTURE\_NOT\_READY
- CREDENTIAL\_EVIDENCE\_ACTIVATION\_BOUNDARY\_INVALID
- CREDENTIAL\_EVIDENCE\_COMPLETED\_REGISTER\_DRIFT
- CREDENTIAL\_EVIDENCE\_UPDATED\_REGISTER\_BLOCKED

## Current State

The real preflight currently fails on:

CREDENTIAL\_EVIDENCE\_URL\_MISSING

No external credential authority or bearer secret is configured in the workspace. No capture artifact was produced, neither register was populated with synthetic evidence, the credential gate remains **BLOCKED**, and activation remains unauthorized.